SOSIALISASI TIM

Aman Pakai AI Coding Assistant

Cara mencegah AI membaca credentials, .env, dan file sensitif di project kita

[Nama Pemateri] · [Tanggal]

AI assistant bisa membaca isi project kita

01

Membaca sesuai kebutuhan

Agent mencari dan membuka file yang relevan dengan tugas, di seluruh folder project.

02

Termasuk file rahasia

.env, private key, sertifikat, dan file config ikut terbaca kalau tidak dibatasi.

03

Dikirim ke server penyedia

Isi file yang dibaca diproses di server penyedia AI, misalnya Anthropic atau Google.

Credentials yang terbaca AI sudah keluar dari laptop kita.

Untuk aplikasi perbankan, ini termasuk risiko kebocoran data yang harus dicegah sejak awal, bukan setelah terjadi.

Aturan utama: rahasia tidak tinggal di folder project

1. Credentials asli disimpan di **secret manager** atau **environment variable sistem**
2. File **.env** lokal hanya berisi nilai dummy atau nilai untuk dev
3. Repo hanya menyimpan **.env.example** tanpa nilai asli

Tiga lapis perlindungan

LAPIS 1 · PALING KUAT

Tidak ada rahasia di project

Kalau file-nya tidak ada, tidak ada yang bisa terbaca.

LAPIS 2

Aturan blokir di tool AI

settings.json untuk Claude Code, .aiexclude dan .geminiignore untuk Gemini.

LAPIS 3

Kontrol perintah terminal

Agent minta izin sebelum menjalankan perintah, dan perintah ke file sensitif ditolak.

Claude Code: aturan deny di settings.json

```
{
  "permissions": {
    "deny": [
      "Read(./.env)",
      "Read(./.env.*)",
      "Read(./**/*.pem)",
      "Read(./**/*.key)",
      "Read(./**/*.p12)",
      "Read(./secrets/**)",
      "Read(./config/credentials*)"
    ]
  }
}
```

Letakkan di salah satu:

`.claude/settings.json`

Berlaku untuk tim, ikut di-commit

`.claude/settings.local.json`

Hanya untuk diri sendiri

`~/.claude/settings.json`

Berlaku di semua project

Gemini: file ignore ala .gitignore

```
# .aiexclude
.env
.env.*
*.key
*.pem
*.p12
apikeys.txt
secrets/
config/credentials*
```

Gemini Code Assist (plugin WebStorm)

File .aiexclude di root project. Di JetBrains, pakai nama dan lokasi default karena pengaturannya tidak bisa diubah.

Gemini CLI (terminal)

File .geminiignore di root project, formatnya sama.

Soal .gitignore

Ikut dipakai, tapi tetap tulis file sensitif secara eksplisit.

Perbandingan singkat per tool

Aspek	Claude Code	Gemini Code Assist	Gemini CLI
Cara blokir	permissions.deny	.aiexclude	.geminiignore
Format	Read(...) dalam JSON	Pola .gitignore	Pola .gitignore
Level global	~/.claude/settings.json	Tidak ada	Tidak ada
Blokir terminal	Sebagian, via Bash(...)	Tidak menjalankan shell	Tidak lewat ignore file
Celah utama	Variasi perintah bash	Paling kecil	Perintah shell

Celah yang perlu diingat: perintah terminal

Aturan blokir hanya menahan alat baca file milik AI.

Perintah shell seperti cat .env masih bisa membaca file yang sama.

Biarkan agent selalu minta izin sebelum menjalankan perintah

Tolak perintah yang menyentuh .env, key, atau folder secrets

Di Claude Code, tambahkan deny seperti Bash(cat .env*)

Tetap andalkan Lapis 1: rahasia tidak ada di project

Cek dalam satu menit

LANGKAH 1

Sebelum

Minta AI membaca isi file .env. Perhatikan isinya terbaca.

LANGKAH 2

Pasang aturan

Tambahkan settings.json atau .aiexclude di root project.

LANGKAH 3

Ulangi

Minta hal yang sama. Permintaan harus ditolak.

Saat demo, gunakan .env berisi nilai dummy.

Jadikan standar di setiap repo

Commit file konfigurasi

.claude/settings.json dan .aiexclude masuk ke setiap repo project.

Template project baru

File konfigurasi sudah ada sejak project dibuat.

Checklist PR review

Tambahkan poin: tidak ada credentials yang ter-commit.

PIC dan evaluasi

[Nama PIC] menjawab pertanyaan; semua repo dicek ulang dalam [2 minggu].

Pertanyaan?

Panduan lengkap dan template konfigurasi: [link dokumen panduan]

PIC: [Nama PIC]